

Notes

This presentation explains the Security and agents action area of SEVEN-G, the framework for the governance, value and measurement of AI. It answers three questions: how AI is protected, what an agent may do and which suppliers the company works with.

What it is for. Until recently, a company's AI answered questions or summarised documents. Now agents are appearing: systems that execute actions with tools and permissions. They pay, write to customers, change data or touch production systems. When a system acts, an error or an attack is no longer a bad answer: it becomes an action with effects. That is why AI security is a matter for management and the board, not only for the technical team.

What you will find in the ten slides:

- Why it matters: what AI changes in the company's risk.
- The key concepts, with the glossary definitions (document 02).
- How SEVEN-G treats it: autonomy levels A0 to A3, what is required at each one and who decides.
- At which gate of the lifecycle each thing is checked and with which templates.
- A fictitious case, frequent mistakes, questions for management or the classroom, the relationship with other areas and how to start.

Why it matters. The basic rule of the area is simple: the more autonomy an agent has, the more controls it needs. And the controls are decided before production, not after the first incident.

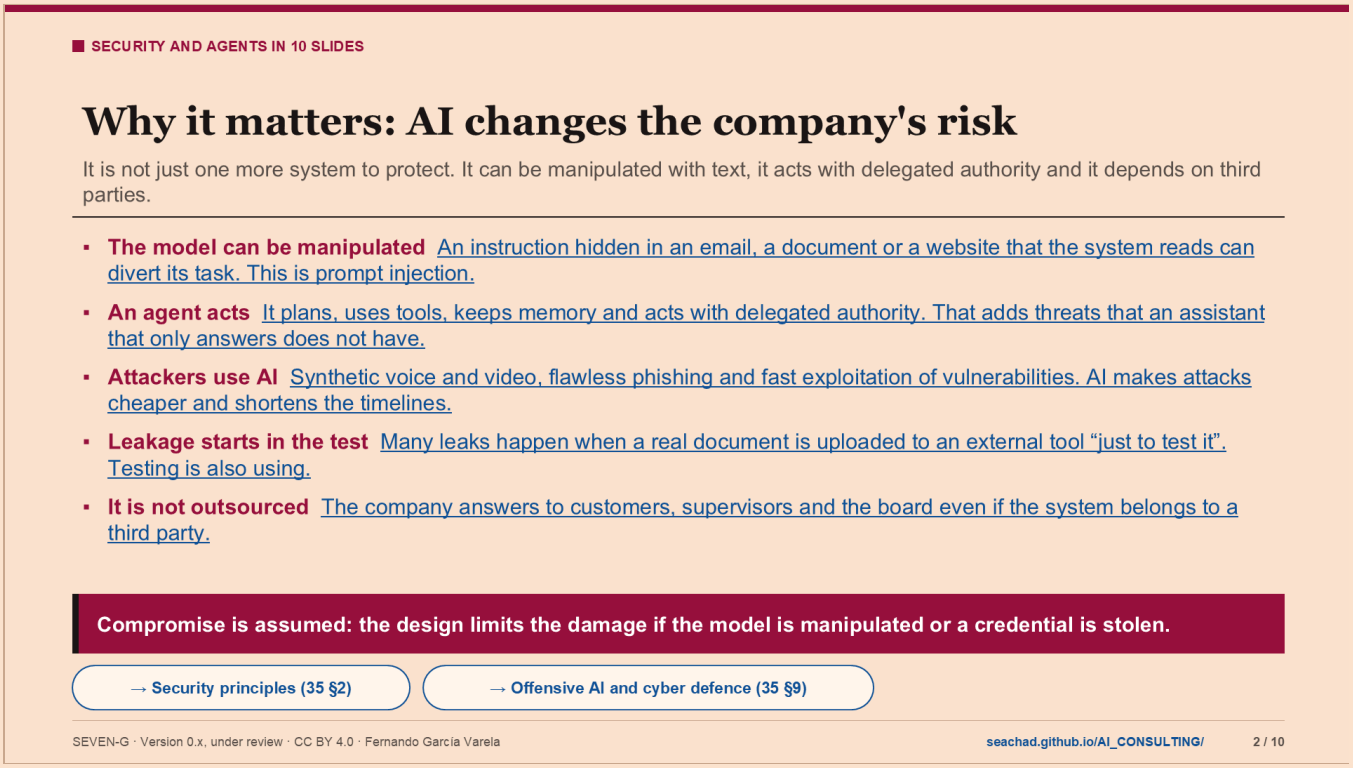
Question for the classroom: how many systems in your organisation already execute actions on their own, and who knows about it?

SOURCES AND LINKS

- **Security and agents area page** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/areas/seguridad.html
- **Document 35 · AI and agent security: purpose and scope** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#purpose-and-scope

SECURITY AND AGENTS IN 10 SLIDES

- **Document 36 · Third parties and AI suppliers** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/36_SEVEN-G_Terceros_y_proveedores_de_IA.html
- **AI and agent security (35)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html
- **What SEVEN-G is** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/entrada/index.html



Notes

AI is not just one more system to protect with the usual rules. It changes the company's risk in five ways.

- The model can be manipulated with text. Prompt injection introduces orders that alter the intended behaviour. It is direct if the user writes it and indirect if it is hidden in what the system reads: documents, emails, websites or tool responses.
- An agent acts. New threats appear: that it pursues a goal different from the one entrusted to it, that it uses more permissions than its task needs or that it induces a person to approve something inappropriate.
- Attackers also use AI. Most attacks are not new, but AI reduces their cost, makes them more convincing and shortens the timelines. One example is CEO fraud with a fake video call that orders an urgent payment.
- Leakage starts in the test. That is why SEVEN-G says that testing is also using: no external tool is used with internal, personal or confidential data without first assessing the supplier.
- Responsibility is not outsourced. Even if the model belongs to a third party, the company is accountable.

The SEVEN-G response starts with eight principles. The most important one for an executive: the model is not a security boundary. The limits that matter (permissions, amounts, recipients and data) are enforced outside the model. And compromise is assumed: the design starts from the idea that one day the model will be manipulated or a credential will be stolen.

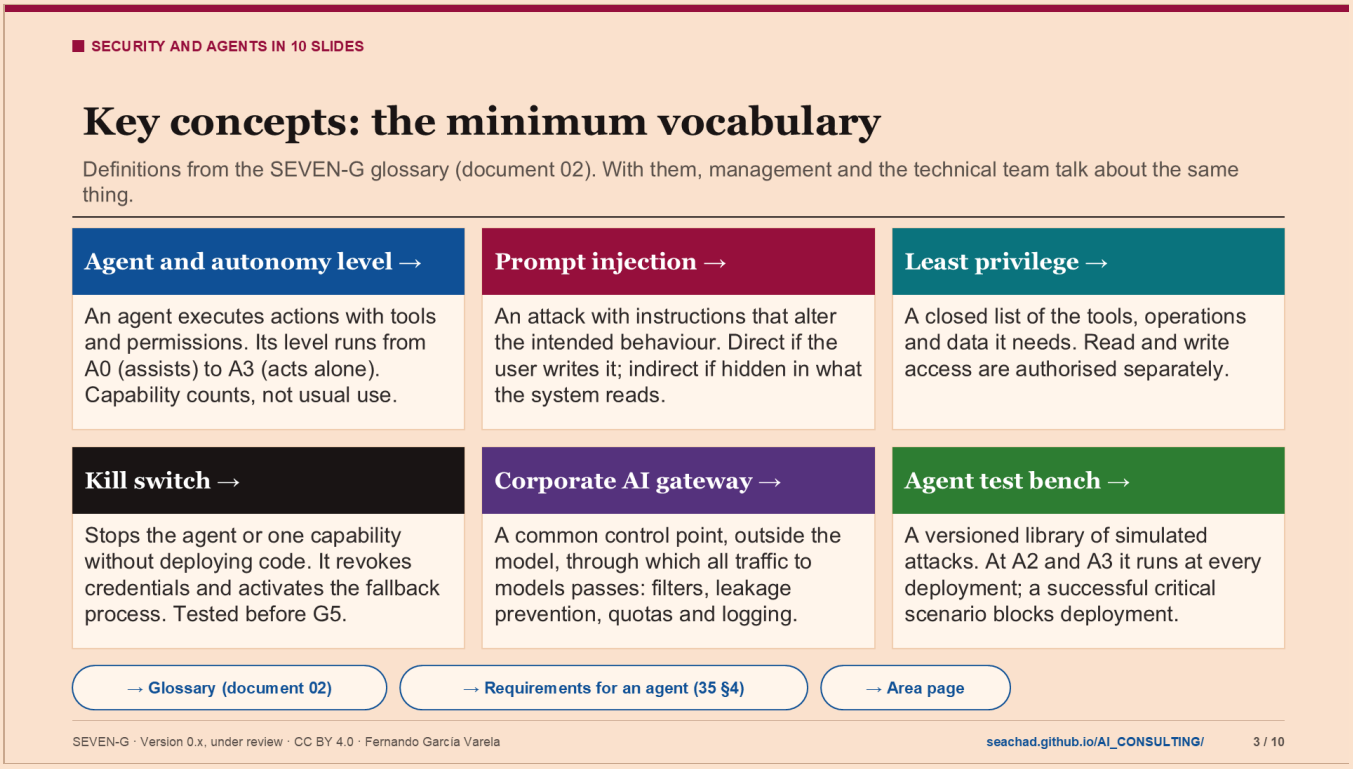
Why it matters. If protection depends on the model obeying, a well-written text is enough to bypass it.

Question for the classroom: does any payment order in your organisation depend only on recognising a voice or a face?

SOURCES AND LINKS

- **Document 35 §2 · Security principles** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#security-principles

- **Document 35 §3 · Threats to AI systems** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#threats-to-ai-systems
- **Document 36 §2 · Principles (testing is also using)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/36_SEVEN-G_Terceros_y_proveedores_de_IA.html#principles
- **OWASP Top 10 for LLM Applications (2025)** https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/
- **CCN-CERT BP/36 · Good practices against offensive AI** https://www.ccn-cert.cni.es/es/informes/informes-de-buenas-practicas-bp/7469-ccn-cert-bp-36-buenas-practicas-ia-ofensiva/file.html
- **Security principles (35 §2)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#security-principles
- **Offensive AI and cyber defence (35 §9)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#exposure-to-offensive-ai-and-use-of-ai-in-cyber-defence



Notes

Six concepts are enough to follow a conversation about AI security. All of them are defined in the SEVEN-G glossary (document 02).

- Agent and autonomy level. An agent is an AI system that executes actions on other systems, data or people, or prepares them for human validation, by means of tools and permissions. The autonomy level measures how much it acts without prior human validation of each action. The level assigned is the highest of the actions the system can execute, not that of its usual use. An agent that almost never pays, but can pay, is classified as if it paid.
- Prompt injection. It is the typical attack on generative AI. Its controls are demonstrated with adversarial testing, not with statements.
- Least privilege. The agent has only what its task strictly needs, and the permissions are justified in the security design (P18).
- Kill switch. When activated, it revokes credentials, blocks new actions, preserves logs and activates the fallback process. The AI operations owner and security can activate it.
- Corporate AI gateway (control SEG-26). It applies the same measured configuration to every initiative. It fails closed for sensitive actions and degraded for queries.
- Corporate agent test bench (control SEG-27). Its scenarios come from the threat model and from the company's own incidents, and they cover all channels: text, documents, email, web, memory, messages between agents and synthetic voice.

A seventh concept completes the area: the AI supplier, the third party that supplies models, platforms or software with AI. It is managed with three requirement levels, from N1 to N3 (document 36).

Why it matters. Without a common vocabulary, “the agent is secure” means nothing. With it, management can ask: what level does it have? who can stop it? does it go through the gateway?

SOURCES AND LINKS

SECURITY AND AGENTS IN 10 SLIDES

- **Glossary (document 02) · Autonomy of systems and agents** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/02_SEVEN-G_Glosario_y_convenciones.html#4-11-autonomy-of-systems-and-agents
- **Document 35 §4 · Essential requirements for an agent** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#essential-requirements-for-an-agent
- **Document 35 §6 · AI security controls (SEG)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#catalogue-of-ai-security-controls-seg
- **Document 36 §4 · Requirement levels N1–N3** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/36_SEVEN-G_Terceros_y_proveedores_de_IA.html#requirement-levels-n1-n3
- **Glossary (document 02)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/02_SEVEN-G_Glosario_y_convenciones.html
- **Requirements for an agent (35 §4)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#essential-requirements-for-an-agent
- **Area page** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/areas/seguridad.html

■ SECURITY AND AGENTS IN 10 SLIDES

How SEVEN-G treats it: controls by autonomy

The level assigned is the highest of what the system can do. A critical control not designed blocks G4; not tested, it blocks G5.

Level	Role of the person	What is required	Who decides
A0 · Assistance	Decides and executes.	Least privilege, secure credentials and external content treated as data.	Level proposed in phase 3 and set in phase 4 (P17 and P18).
A1 · Recommendation	Validates each action before it is executed.	Also: own identity, action log, adversarial testing and human validation of every action.	Recorded in the inventory (T02). Moving up a level is a relevant change.
A2 · Supervised action	Supervises, can interrupt and reviews after the fact.	Also: intent control, limits, a tested kill switch and the test bench at every deployment.	With effects on third parties, money, personal data or production: Enterprise intensity.
A3 · Autonomous action	Sets limits, supervises aggregates and can stop it.	Everything in A2, with more frequent tests and reviews (kill switch, every quarter).	The AI Committee, at G4 and at G5, stating why A2 is not enough.

Proceed with conditions is not permitted for a critical control. Disabling one in production is a critical nonconformity.

→ Autonomy levels (35 §5) → Critical controls (35 §5.4) → Enterprise criteria (01 §9.2)

SEVEN-G · Version 0.x, under review · CC BY 4.0 · Fernando García Varela seachad.github.io/AI_CONSULTING/ 4 / 10

Notes

The table summarises the central rule of the area: the more autonomy, the more controls. Each row adds requirements to the previous one.

- A0 · Assistance. The system informs, summarises or generates content; the person decides and executes. Least privilege, credential management and treating all external content as data are mandatory. If it accesses corporate systems with its own credentials, its own identity and approved tools are also mandatory.
- A1 · Recommendation. The system proposes a specific action and the person validates each one before it is executed. Its own identity, traceability between action and intent, the action log and adversarial testing are added.
- A2 · Supervised action. The system executes actions within defined limits. All applicable agent controls are required: a decision point outside the model that checks each action, amount and volume limits, a kill switch tested every six months and the test bench at every deployment.
- A3 · Autonomous action. The system executes sequences without individual review. The kill switch is tested every quarter and permissions are reviewed every quarter.

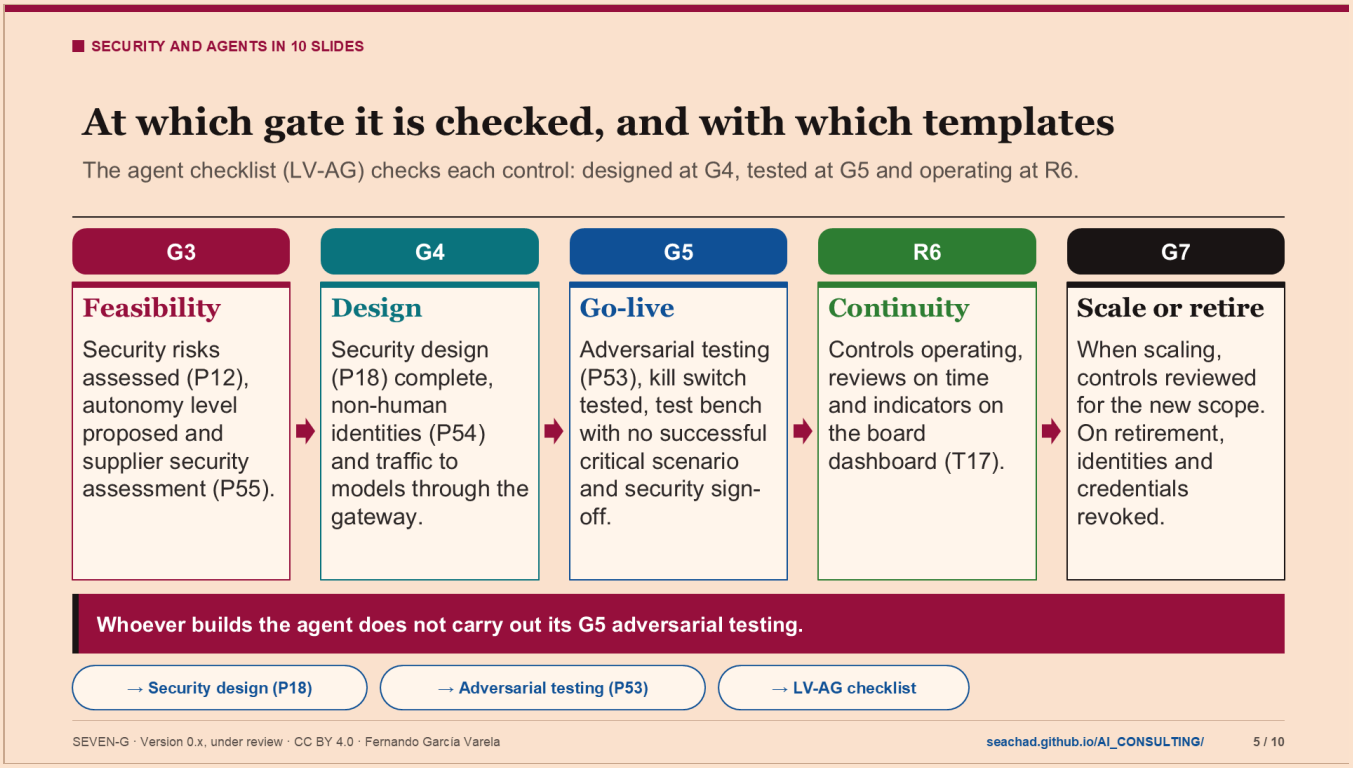
Who decides and when. The level is proposed in phase 3 (feasibility), set in phase 4 (design) and recorded in the inventory. An A2 or A3 system that affects third parties, money, personal data or production meets the criterion of “agents with the ability to act” and goes with Enterprise intensity. An A3 system needs a decision by the AI Committee at G4 and at G5. After a serious incident related to autonomy, the system moves down a level or is stopped until the analysis.

Why it matters. This rule turns “trusting AI” into a concrete decision that is approved, supervised and audited.

Question for the classroom: why does SEVEN-G classify by what the system can do and not by what it usually does?

SOURCES AND LINKS

- **Document 35 §5 · Autonomy levels** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#autonomy-levels
- **Document 35 §5.3 · Minimum controls per level** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#5-3-minimum-controls-per-level
- **Document 35 §7 · Agent controls (AG)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#catalogue-of-agent-controls-ag
- **Document 01 §9.2 · Enterprise criteria** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/01_SEVEN-G_Metodologia_fundacional.html#9-2-enterprise-criteria
- **Autonomy levels (35 §5)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#autonomy-levels
- **Critical controls (35 §5.4)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#5-4-critical-controls
- **Enterprise criteria (01 §9.2)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/01_SEVEN-G_Metodologia_fundacional.html#9-2-enterprise-criteria



Notes

In SEVEN-G each initiative goes through phases separated by decision gates. Security is checked at five of them, always with evidence.

- Feasibility gate (G3). Generative AI and security risks are assessed in the risk matrix (P12). The autonomy level is proposed. If there is a supplier, its security is assessed with the due diligence questionnaire (P55).
- Design gate (G4). The security design (P18) records the threat model, the autonomy level, the identities, the permission matrix, intent control, the limits, the sensitive actions, the kill switch and the test plan. The agents' identities are entered, with their human owner, in the inventory of non-human identities (P54). Traffic to models goes through the corporate gateway.
- Go-live gate (G5). Adversarial testing (red teaming) is carried out and documented in P53. The kill switch is tested. The test bench cannot have any successful critical scenario. Information security signs within the multi-level sign-off.
- Continuity review (R6). It is checked that the controls are still operating and that campaigns and reviews are on time. The indicators reach the board dashboard (T17).
- Scale or retire gate (G7). When scaling, controls are reviewed for the new scope. On retirement, no orphaned identities or credentials may remain.

Who does what. The AI Technical Owner designs and implements the controls. Information security reviews them. The AI Risk Owner assesses the residual risk. The AI Auditor verifies the evidence with the LV-AG checklist. The agent security assessment (T10) is applied with the security design (P18). The AI security profile (P72) gives the overall view in the corporate cycle.

Why it matters. Separating whoever builds from whoever tests prevents anyone from approving their own work.

SOURCES AND LINKS

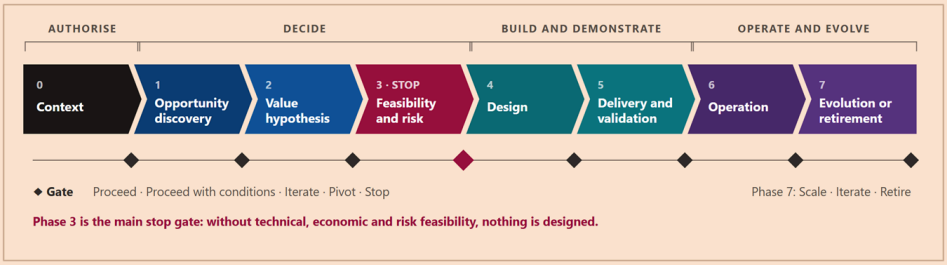
SECURITY AND AGENTS IN 10 SLIDES

- **Document 35 §11 · Integration with the lifecycle** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#integration-with-the-lifecycle
- **Document 35 §12 · Associated tools and templates** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#associated-tools-and-templates
- **Template P54 · Inventory of non-human identities** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/plantillas/P54_SEVEN-G_Inventario_de_identidades_no_humanas_y_componentes.html
- **Template P55 · AI supplier due diligence** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/plantillas/P55_SEVEN-G_Cuestionario_de_diligencia_debida_a_proveedores_de_IA.html
- **Template P72 · AI security profile** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/plantillas/P72_SEVEN-G_Perfil_de_seguridad_de_IA_CSF_y_Cyber_AI_Profile.html
- **Board dashboard (T17)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/herramientas/T17_panel_consejo/index.html
- **Security design (P18)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/plantillas/P18_SEVEN-G_Diseno_de_seguridad.html
- **Adversarial testing (P53)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/plantillas/P53_SEVEN-G_Plan_e_informe_de_pruebas_adversarias.html
- **LV-AG checklist** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/22_SEVEN-G_Listas_de_verificacion_por_gate.html#lv-ag-agents

■ SECURITY AND AGENTS IN 10 SLIDES

A fictitious case: the load booking agent

Fictitious logistics operator from document 92. Limits and the kill switch are set before production; value decides whether it continues.



- **Appetite (C2)** The board accepts A2 agents with a limit per transaction approved by the committee, and no A3 with third-party money.
- **Autonomy A2** The agent books loads of up to €2,500 each. Above that amount, a person decides.
- **G4 · Design** The AI Committee lets it proceed: limit per load, action log and kill switch designed.
- **G5 · Stop** It is stopped on value: a 0.6-point margin improvement, below the 1.0 set. Investment consumed: €165,000.

→ Case 2 · Logistics operator (92) → Action limits (35 §4.5)

SEVEN-G · Version 0.x, under review · CC BY 4.0 · Fernando García Varela seachad.github.io/AI_CONSULTING/ 6 / 10

Notes

The case is fictitious, like all the cases in document 92 (application cases): companies, people and figures are illustrative. A logistics operator wants to open a new service: booking on-demand transport capacity for its customers with an agent that buys loads on freight exchanges. It is a Transform bet, with Enterprise intensity.

How the area is applied, step by step:

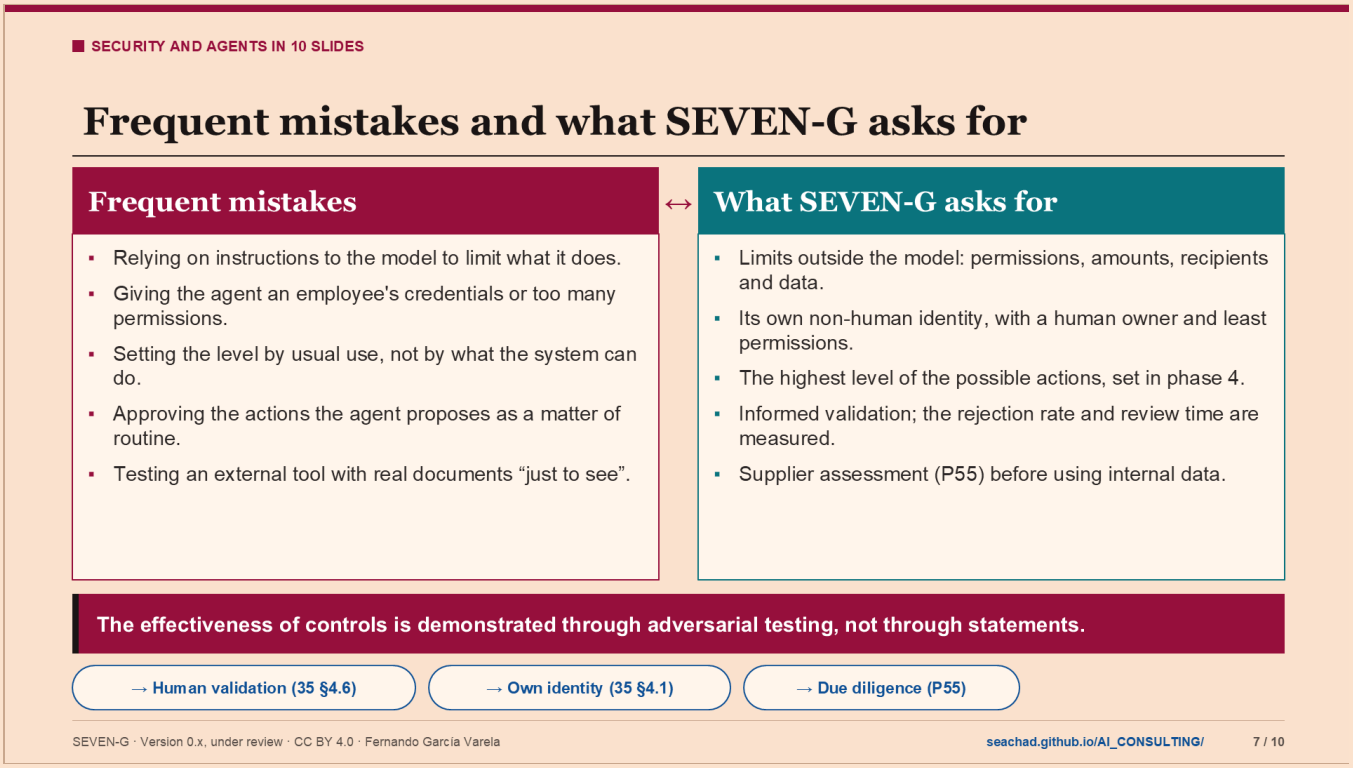
- Risk appetite. At the direction stage (C2) the board sets how far it goes: agents with supervised action (A2), with a financial limit per transaction approved by the committee, and no A3 in transactions involving third-party money. Security starts at the board, before the agent exists.
- Autonomy level. The agent acts alone up to €2,500 per load. Above that, a person decides. It is an action limit enforced outside the model, not an instruction the model could forget.
- Design gate (G4). The AI Committee checks that the limit per load, the action log and the kill switch are designed.
- Go-live gate (G5). A pilot with random assignment (520 loads with the agent and 510 in the control group) gives a margin improvement of 0.6 points, below the 1.0 set as the stop criterion. Errors: 0.8 %. The committee stops the initiative. The team asked for another iteration with a lower threshold and the board decided not to relax the criteria.

What it teaches. Security controls do not make a use case good: they let it work without harm if its value is demonstrated. Here the value was not demonstrated, and the company stopped with €165,000 invested and a recorded lesson. The image shows the lifecycle, with its phases and gates.

Question for the classroom: if the pilot had reached the margin, what would have had to be tested before putting the agent into production?

SOURCES AND LINKS

- **Document 92 · Case 2, logistics operator L (fictitious)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/92_SEVEN-G_Casos_de_aplicacion.html#case-2-logistics-operator-l-fictitious
- **Document 35 §4.5 · Action limits** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#4-5-action-limits
- **Document 35 §4.7 · Kill switch** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#4-7-kill-switch
- **Case 2 · Logistics operator (92)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/92_SEVEN-G_Casos_de_aplicacion.html#case-2-logistics-operator-l-fictitious
- **Action limits (35 §4.5)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#4-5-action-limits



Notes

Five frequent mistakes, each with the SEVEN-G rule that prevents it.

- Relying on instructions to the model. Telling the model “do not make payments of more than a thousand euros” helps, but an attacker can bypass it with another instruction. SEVEN-G enforces limits outside the model, with an independent decision point that blocks whatever does not fit.
- An employee's credentials or too many permissions. If the agent uses a person's account, nobody knows who did what. SEVEN-G requires its own identity, registered with its human owner, and a closed list of permissions. When it acts on behalf of a user, it never has more permissions than that user.
- Setting the level by usual use. A system that almost always proposes, but can execute, is an acting system. It is classified by what it can do.
- Routine approval. If a person approves a hundred actions a day without reading them, human validation does not protect. SEVEN-G asks for informed validation: the person sees which action is proposed, with which data, why and with what effects, and can reject it at no cost to themselves. The rejection rate and review time are measured to detect routine approval.
- Testing with real documents. No external tool is used with internal, personal or confidential data without the supplier assessment proportionate to its level. A test with synthetic or public data does not need it.

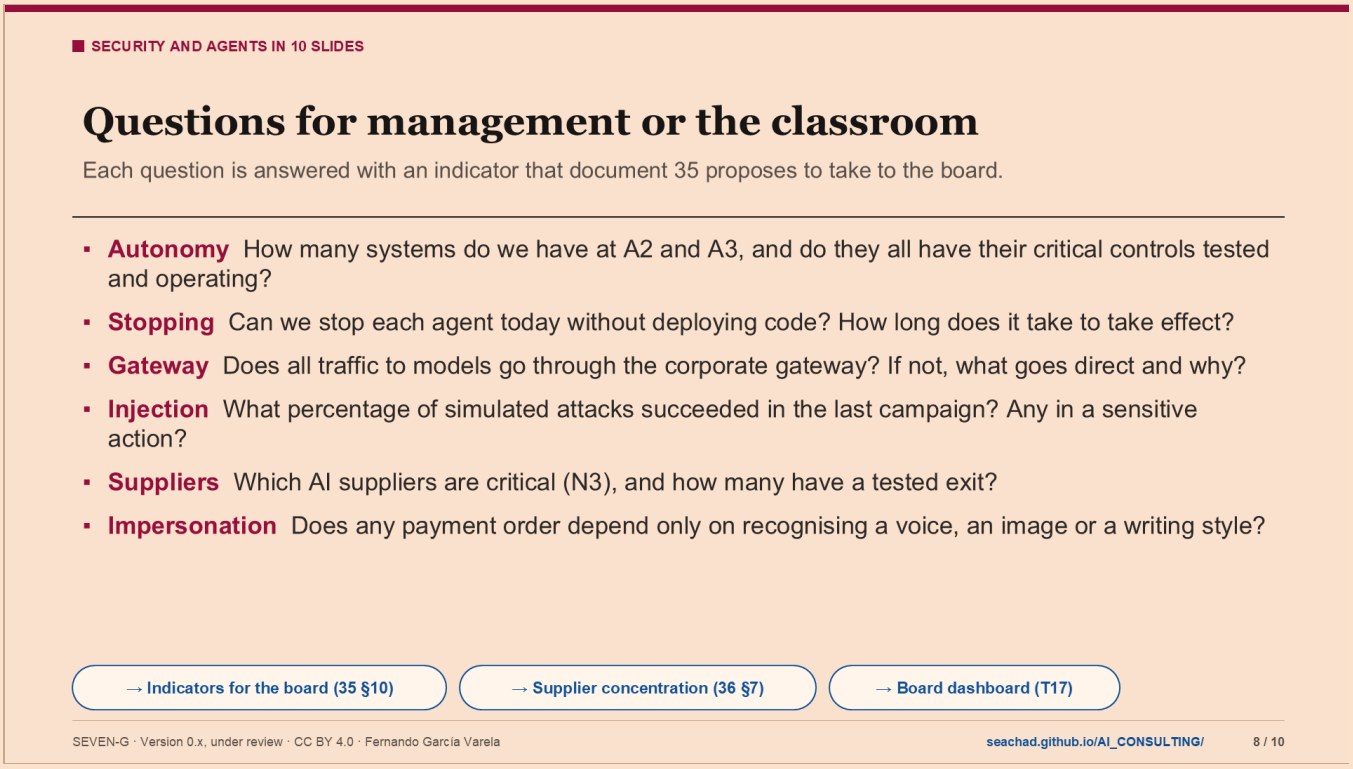
Why it matters. All these mistakes have something in common: they give a feeling of control that nobody has checked. SEVEN-G asks for it to be demonstrated with adversarial testing.

Question for the classroom: which of these five mistakes do you think is most frequent in your organisation?

SOURCES AND LINKS

- **Document 35 §2 · Security principles** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#security-principles
- **Document 35 §4.4 · Intent-based access control** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#4-4-intent-based-access-control

- **Document 35 §4.6 · Human validation of sensitive actions** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#4-6-human-validation-of-sensitive-actions
- **Document 36 §2 · Principles (testing is also using)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/36_SEVEN-G_Terceros_y_proveedores_de_IA.html#principles
- **Human validation (35 §4.6)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#4-6-human-validation-of-sensitive-actions
- **Own identity (35 §4.1)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#4-1-own-identity
- **Due diligence (P55)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/plantillas/P55_SEVEN-G_Cuestionario_de_diligencia_debida_a_proveedores_de_IA.html



Notes

These six questions are useful for a board session, a management committee or a classroom case. Each one is backed by an indicator from document 35 (section 10) or document 36 (section 7), with its expected reading.

- Autonomy. Indicators: systems by autonomy level and critical agent controls. Reading: A2 and A3 systems may grow, but with 100 % of their critical controls tested and operating. Any deviation is explained.
- Stopping. Indicator: kill switch test. Reading: 100 % of A2 and A3 systems with a current test and a measured time to take effect.
- Gateway. Indicator: traffic through the corporate gateway. Reading: 100 %; direct traffic is explained and regularised.
- Injection. Indicator: success of prompt injection in the last adversarial testing campaign. Reading: a downward trend and zero in sensitive actions.
- Suppliers. Concentration indicators: systems per supplier, value that depends on each one and critical suppliers without a tested exit. For N3 suppliers, the exit is tested at least once a year or before renewal.
- Impersonation. Governance measure: no payment order depends only on recognising a voice, an image or a writing style. At least one annual drill of fraud with synthetic impersonation is run, involving finance and management.

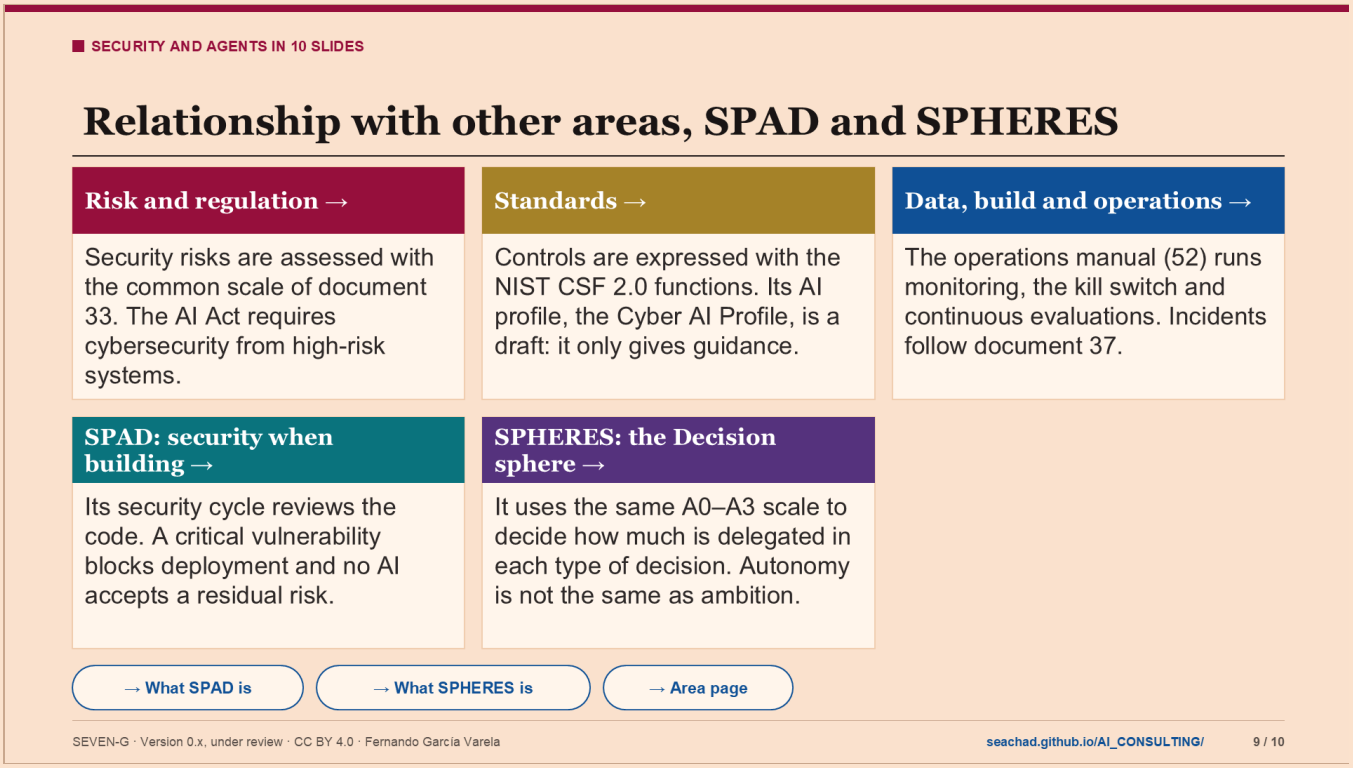
How to use them in the classroom. Ask students to choose a company they know and answer with what they know. The usual finding is that several answers are “we don't know”. That finding is already the first result.

Why it matters. The board does not need to understand how a model works. It needs to ask the right questions and require a figure behind each answer. In SEVEN-G those indicators reach the board dashboard (T17).

SOURCES AND LINKS

SECURITY AND AGENTS IN 10 SLIDES

- **Document 35 §10 · Indicators for the board** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#indicators-for-the-board
- **Document 35 §9.2 · Governance measures against offensive AI** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#9-2-governance-measures
- **Document 36 §7 · Technological dependency and concentration** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/36_SEVEN-G_Terceros_y_proveedores_de_IA.html#technological-dependency-and-concentration
- **Indicators for the board (35 §10)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#indicators-for-the-board
- **Supplier concentration (36 §7)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/36_SEVEN-G_Terceros_y_proveedores_de_IA.html#7-2-concentration
- **Board dashboard (T17)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/herramientas/T17_panel_consejo/index.html



Notes

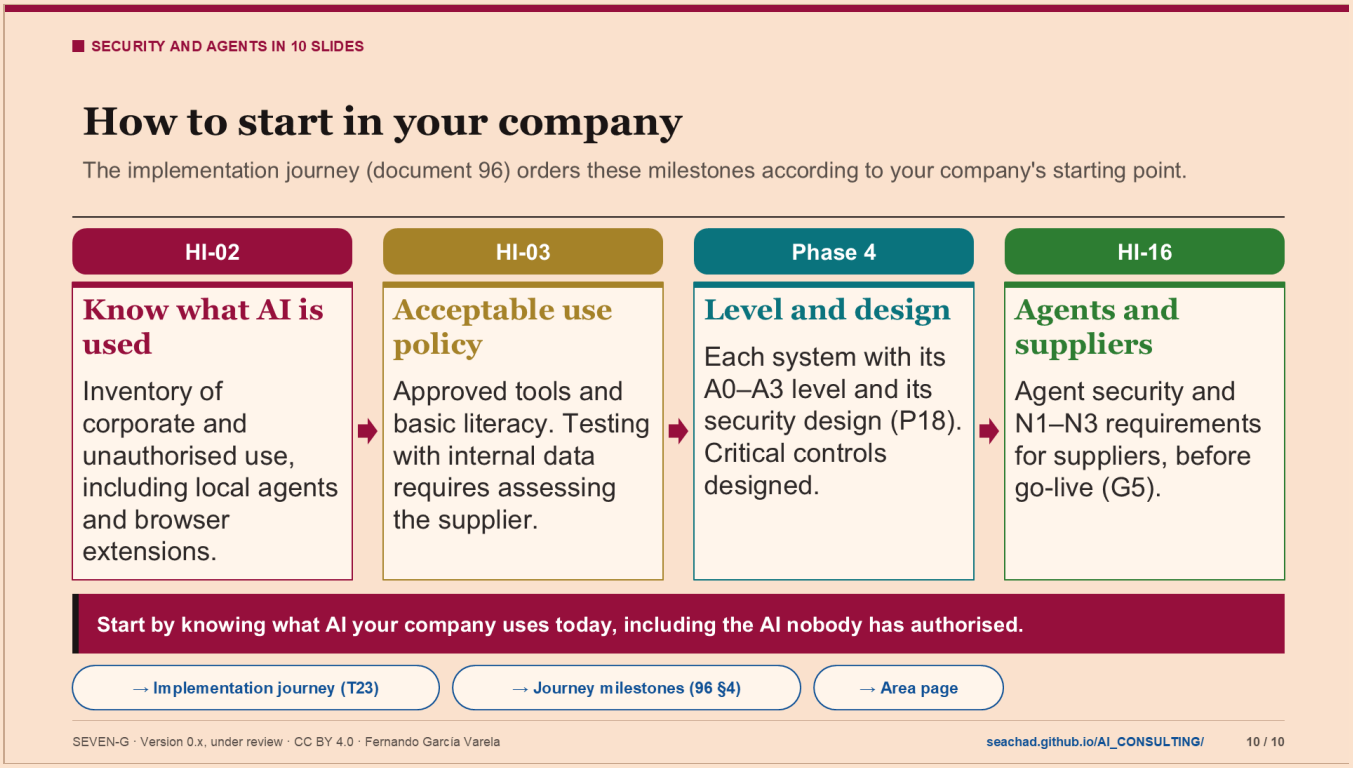
AI security does not stand alone. It relies on other SEVEN-G areas and on the author's other two frameworks, which are independent methodologies that reference each other.

- Risk and regulation. Security threats have their own typical risks (generative AI and security) that are assessed with the probability by impact scale of document 33. The EU AI Act requires high-risk systems to have an appropriate level of accuracy, robustness and cybersecurity, including resilience against manipulation of data and models.
- Standards. Each SEVEN-G security control states the NIST CSF 2.0 function it contributes to: govern, identify, protect, detect, respond and recover. With that, the AI security profile (P72) is built. NIST's AI profile, the Cyber AI Profile, is still a preliminary draft: it is used only as guidance and never underpins a gate criterion.
- Data, build and operations. The operations manual (document 52) runs monitoring, the kill switch and continuous evaluations, and measures guardrail effectiveness. AI security incidents follow the nonconformities and incidents circuit (document 37).
- SPAD. It is the methodology for building software with AI. Its security cycle is mandatory for authentication, payments, personal data, untrusted inputs and AI components in production. A critical vulnerability blocks deployment, and the AI security reviewer classifies and recommends, but a person accepts. For systems with agents, SPAD uses the same autonomy scale.
- SPHERES. It is the explanatory layer of the spheres. In sphere 07 (Decision) it uses the A0–A3 scale to decide how much is delegated in each type of decision. It reminds us that the autonomy level is not the same as the ambition level.

Why it matters. The same vocabulary in the three frameworks prevents the board, the product team and the development team from talking about different things.

SOURCES AND LINKS

- **Document 34 §5.3 · NIST CSF 2.0 and Cyber AI Profile (draft)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/34_SEVEN-G_Mapeo_regulatorio.html#5-3-nist-csf-2-0-and-cyber-ai-profile
- **SPAD 04 · Security cycle** https://seachad.github.io/AI_CONSULTING/SPAD/html/en/04_SPAD_Ciclos_complementarios.html#security-cycle
- **SPHERES 03 · The four autonomy levels** https://seachad.github.io/AI_CONSULTING/SPHERES/html/en/03_SPHERES_Esferas_habilitadoras.html#the-four-autonomy-levels
- **The NIST Cybersecurity Framework (CSF) 2.0** https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final
- **NIST IR 8596 · Cyber AI Profile (initial preliminary draft)** https://csrc.nist.gov/pubs/ir/8596/iprd
- **Regulation (EU) 2024/1689 (EU AI Act)** https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng
- **What SPAD is** https://seachad.github.io/AI_CONSULTING/SPAD/html/en/00_SPAD_Que_es_y_para_que_sirve.html
- **What SPHERES is** https://seachad.github.io/AI_CONSULTING/SPHERES/html/en/00_SPHERES_Que_es_y_para_que_sirve.html
- **Area page** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/areas/seguridad.html



Notes

There is no need to set everything up at once. The SEVEN-G implementation journey (document 96) orders the milestones according to each company's starting point. For this area, four steps mark the way.

- Know what AI is used (milestone HI-02). The AI Office and security carry it out. It includes unauthorised use: external assistants with company data, local agents with credentials on devices and AI browser extensions. Everything is inventoried and authorised like any other tool. If there is evidence of unauthorised use, or it is not known, this milestone moves to top priority.
- Acceptable use policy (milestone HI-03). It sets which tools are approved and includes basic training. It applies the principle that testing is also using.
- Level and design (phase 4 of each initiative). Each system receives its autonomy level and its security design (P18). Critical controls are designed before the design gate (G4).
- Agents and suppliers (milestone HI-16). Security, procurement and risk lead it: the agent requirements of document 35 and the N1, N2 or N3 requirements for each supplier according to document 36. It must be ready before go-live (G5).

The implementation journey tool (T23) classifies the company's starting point with a questionnaire and shows the prioritised journey. It works in the browser with fictitious example data.

Why it matters. What is not inventoried cannot be protected. Starting with the inventory and the policy is cheap and gives the board a first honest answer: what AI we use and who controls it.

Question for the classroom: if you had to take an inventory of your organisation's AI tomorrow, who would you ask first?

SOURCES AND LINKS

- **Document 96 §4 · The journey milestones** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/96_SEVEN-G_Puntos_de_partida_y_recorrido_de_implantacion.html#the-journey-milestones
- **Document 31 §4.7 · Personal agents and automations** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/31_SEVEN-G_Politica_corporativa_y_uso_aceptable.html#4-7-personal-agents-and-automations

SECURITY AND AGENTS IN 10 SLIDES

- **Document 35 §6 · Control of corporate AI use (SEG-20)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/35_SEVEN-G_Seguridad_de_IA_y_agentes.html#catalogue-of-ai-security-controls-seg
- **Tool T23 · Implementation journey** https://seachad.github.io/AI_CONSULTING/SEVEN-G/herramientas/T23_recorrido_implantacion/recorrido.html
- **Implementation journey (T23)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/herramientas/T23_recorrido_implantacion/recorrido.html
- **Journey milestones (96 §4)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/96_SEVEN-G_Puntos_de_partida_y_recorrido_de_implantacion.html#4-1-what-each-milestone-is-who-does-it-and-how-it-is-substantiated
- **Area page** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/areas/seguridad.html

LEGAL NOTICE

Legal notice: a generic, free methodological aid provided "as is" for information purposes; it is not legal advice and has not been legally reviewed for any case. Each organisation adapts it and is responsible for its legal review and its regulatory compliance; it may not reflect recent regulatory changes. To the fullest extent permitted by law, the author accepts no liability whatsoever for the effects of its application. It does not grant certification of any kind. Details in document 93.

CC BY 4.0 (content) · MIT (code) · Fernando García Varela · seachad.github.io/AI_CONSULTING/